eBook

Securing the Next-Generation Customer Experience



databricks

Introduction

Retailers increasingly compete on customer experience. Their ability to recognize and respond to customer signals often depends on their ability to assimilate large volumes of information from a wide variety of customer touchpoints. These 360-degree views of the customer provide insights into customer needs and preferences and enable an organization's marketing team to tailor experiences to the individual.

But inherent in the contract between the customer and the retailer is an expectation that this sensitive information will be protected and used in ways that serve the needs of the customer, not just the retail organization.

This goes beyond the explicit terms and conditions through which these data were acquired. Implicit in the relationship between the retailer and its customers is the expectation that personal information collected as part of the retail engagement will be protected from misuse. Increasingly, government agencies are stepping in to formalize these expectations, but no responsible organization can pursue a next-generation customer experience, built upon troves of customer data, without the formalization of policies and procedures for the governance and protection of these data whether or not required by contracts and government policy.



Securing Customer Data in the Databricks Data Intelligence Platform

With the emergence of the Databricks Platform as a preferred store for these customer data — either as the central store of data in a composable customer data platform (CDP) architecture or as a partner platform for a packaged CDP — it is important we outline well-established and generally accepted practices for the management of customer data in the lakehouse. To do so, we've partnered with our friends at LFG Security Consulting, a data privacy and cybersecurity consultancy specializing in the needs of retail organizations, to assemble this document, providing an outline of the key areas retail organizations need to focus on as they accumulate more and more customer data within the Databricks Platform.



Where to Begin

The protection of customer data in the Databricks Platform begins with an assessment of the organization's current security posture and processes along with the use of the protective features and capabilities built into the platform and surrounding cloud environment. While conducting self-assessments is a good practice, we recommend employing expert, consultant-led assessments to identify and prioritize security and privacy risks while building a holistic data strategy. An outside perspective — from an entity familiar with industry and regulatory standards and best practices, and capable of advocating for changes to established patterns and processes — is often needed to uplevel the organization and ensure that data are adequately protected.

At a minimum, an assessment should focus on three distinct aspects of data protection and governance. These are:

- **Data security** — the protection of data from unauthorized access through controls managed by the retail organization
- **Data privacy** — the protection of data from unauthorized use through controls managed by the retail organization
- **Cloud security** — the protection of data from unauthorized access through controls managed by the platform provider

Data Security

Next-generation customer experience initiatives rely heavily on the consolidation of customer data from a variety of source systems. This makes the CDP, a centralized repository of customer data, a particularly appealing target for bad actors, where inadequate protections can lead to data exposure, undermining rigorous controls placed on upstream systems.

An assessment of the data security posture is focused on three principal areas:

- Access management
- Network and storage security
- Incident response protocols



Access management

- **Review of user access controls:** Identify privileged users, access levels and permissions granted to various roles and user groups. Analyze access logs for unusual activity and potential unauthorized access attempts.
- **Review of authorization mechanisms:** Evaluate the effectiveness of multi-factor authentication, role-based access control and least privilege principles in restricting access to sensitive data.
- **Review of identity and access management (IAM) systems:** Assess the configuration and security of IAM systems used to manage user accounts and access permissions.



Network and storage security

- **Review of network segmentation and isolation:** Analyze network topology to ensure proper segmentation of sensitive data and critical systems. Evaluate the effectiveness of firewalls, intrusion detection/prevention systems (IDS/IPS) and other network security controls.
- **Review of data encryption:** Assess the encryption methods used for data at rest and in transit. Evaluate the strength of encryption algorithms and key management practices.
- **Review of vulnerability management:** Analyze vulnerability scanning and patching procedures to ensure timely identification and remediation of security weaknesses in network devices and systems.



Incident response protocols

- **Review of incident response plans and procedures:** Assess the effectiveness of incident response plans in identifying, containing and recovering from security incidents. Evaluate the incident response team's training, communication practices, and procedures for reporting and escalating security incidents.
- **Review of forensic capabilities:** Evaluate the tools and processes used for digital forensics and incident investigation.
- **Review of breach notification procedures:** Assess the retailer's procedures for notifying customers and regulatory authorities in case of a data breach.

Details on how to best address access management and network and storage security concerns within the Databricks Platform are provided within the Databricks Security Best Practices documentation for deployments on AWS, Azure and GCP. Incident response protocols should be defined explicitly within the context of a given organization's processes, risks and obligations, something an experienced consultancy is best equipped to help the organization define.

Data Privacy

Next-generation customer experiences initiatives involve the collection of vast amounts of customer data and the extraction of rich insights into pending behaviors, raising significant privacy concerns. Tight controls over authorized users and authorized uses of this data help ensure the data is employed as expected. And transparency with customers about the information resources and their intended uses, as well as procedures for the correction or removal of personal data and revocation of authorization to use such data in particular practices, go a long way to not just meeting regulatory requirements (e.g., GDPR, CCPA/CPRA; see below) but maintaining trust.

An assessment of the data privacy posture is focused on four principal areas:

- Data inventory and mapping
- Data subject rights and opt-out mechanisms
- Compliance with regulatory requirements
- Data security and privacy awareness



Data inventory and mapping

- Identification of all personal data collected across all systems, touchpoints and departments. This includes details such as customer names, addresses, email addresses, phone numbers, purchase history, browsing behavior, loyalty program data and data tags associated with this information.
- Mapping data flows to understand how data is collected, stored, used, shared and deleted. This involves understanding the various systems and processes involved in handling customer data, including data warehousing, analytics platforms, marketing automation tools and third-party integrations, while also tracing the data lineage.
- Categorization of data based on sensitivity and regulatory requirements. This helps prioritize data protection measures based on the potential risks associated with different types of data.



Data subject rights and opt-out mechanisms

- Review of processes for responding to data subject access requests (DSARs) for information, rectification, deletion and restriction of processing. This includes assessing the timeliness, completeness and accuracy of responses to DSARs, as well as the procedures in place for verifying data subject identities and handling complex requests.
- Assessment of the effectiveness of opt-out mechanisms for marketing communications and data sharing. This involves evaluating whether opt-out mechanisms are easy to find, understand and use, and whether they effectively prevent unwanted marketing communications and data sharing.
- Evaluation of data minimization practices to limit the collection and retention of personal data. This includes assessing whether data collected is necessary for the stated purposes, whether it is retained for the minimum amount of time necessary, and whether anonymization or pseudonymization could be used instead of collecting personal data.



Compliance with regulatory requirements

- Identification of relevant data privacy regulations applicable to the retailer's operations. This could include regulations such as the General Data Protection Regulation (GDPR), California Consumer Privacy Act (CCPA) and California Privacy Rights Act (CPRA).
- Gap analysis to assess compliance with the regulations' requirements for data governance, consent, transparency and security. This involves evaluating whether the retailer has the necessary policies, procedures and controls in place to meet the requirements of the relevant regulations.
- Recommendations for achieving and maintaining compliance with data privacy regulations. This includes providing specific guidance on how to address identified gaps in compliance and implement best practices for data privacy management.

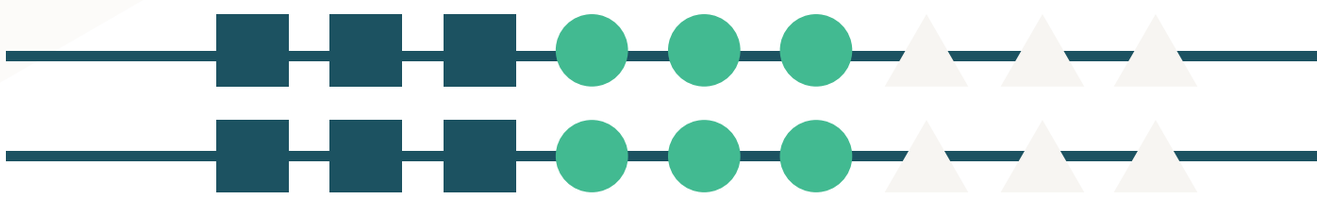


Data security and privacy awareness

- Assessment of employee training programs on data privacy and security best practices. This involves evaluating whether employees have the knowledge and skills necessary to handle customer data securely and responsibly, and whether training is provided on an ongoing basis.
- Review of internal communication channels for raising data privacy concerns and reporting potential violations. This includes assessing whether employees have easy and accessible ways to report data privacy concerns and whether these concerns are taken seriously and investigated thoroughly.
- Evaluation of the overall data privacy culture within the organization. This involves assessing the organization's commitment to data privacy, its leadership's support for data privacy initiatives, and the overall attitude of employees toward data privacy.

Within Databricks, there are numerous features and capabilities that can be employed to help organizations achieve their objectives in many of these areas. With regard to data inventory and mapping, Databricks provides a centralized catalog known as Unity Catalog for tracking and governing information assets. A key feature of Unity Catalog is native support for the capture and querying of data lineage information as well as support for data tagging and data masking.

While much of the management of data subject rights and opt-out mechanisms falls outside the scope of the Databricks Platform, certain capabilities such as the default use of the Delta Lake format can assist organizations as they apply these policies to large volumes of data housed within the platform. Similarly, compliance with data privacy regulations requires the adoption of a broad range of management practices, but building data management solutions on a compliance-aligned platform is always a good first step. You can review Databricks' compliance documents for common certifications and standards here.



Cloud Security

Housing customer data in a cloud service such as Databricks requires the owner of the data to understand the division of responsibilities between the cloud provider, the platform service provider, i.e., Databricks, and itself. A review of policies and procedures implemented by external parties should be performed to ensure that service-provider standards align with the needs of the organization. Best practices for the configuration of these services provided by the cloud provider and Databricks should also be periodically reviewed and updates to service configurations should be implemented to protect sensitive data in alignment with these evolving recommendations.

Areas of focus in this assessment are on:

- Identity and access management (IAM)
- Data encryption and security
- Cloud security configuration
- Monitoring and logging



Identity and access management (IAM)

- Review of cloud platform IAM configurations, including user roles, permissions and access controls. This includes analyzing access granted to data pipelines, analytics platforms and other components involved in customer experience initiatives.
- Assessment of additional IAM components implemented on top of cloud IAM, such as user provisioning and access governance tools.
- Assessment of identity federation and single sign-on (SSO) implementation for secure access to cloud resources.
- Evaluation of multi-factor authentication (MFA) enforcement for all cloud accounts, particularly those with access to sensitive customer data or critical systems.



Data encryption and security

- Review of data encryption practices for data at rest and in transit within the cloud environment. This includes evaluating encryption algorithms used, key management procedures and secure storage solutions.
- Assessment of data loss prevention (DLP) solutions to prevent unauthorized exfiltration of customer data
- Evaluation of data protection techniques for sensitive data elements



Cloud security configuration

- Review of cloud platform configurations for security best practices, including security groups, network access controls and logging settings
- Identification of potential misconfigurations that could introduce security vulnerabilities, particularly those related to data access, resource management and API security
- Recommendations for optimizing cloud security settings to improve the overall security posture of resources used, aligning with industry best practices and relevant cloud security standards

Monitoring and logging

- Review of cloud platform logging and monitoring capabilities for detecting suspicious activity and security incidents. This includes analyzing logs for data access anomalies, unauthorized API calls and potential threats to customer data.
- Assessment of the effectiveness of log analysis tools and incident response procedures
- Recommendations for improving security monitoring and incident detection capabilities within the cloud environment, focusing on activities and data relevant to sensitive projects

A great place to start with the cloud assessment is the Databricks Trust Center, where details about Databricks' internal security practices, audits and certifications can be obtained. The Shared Responsibility Model documentation (for AWS, Azure and GCP), accessible through the Trust Center, should also be reviewed to understand the division of responsibilities between Databricks and each of the major cloud platforms on which it runs. A review of the Trust Center documentation of the cloud providers — i.e., AWS, Azure and GCP — and an exploration of the specific security guidance for the cloud-provider storage and networking services frequently employed with Databricks should also be performed.



The result of the initial three-part security and privacy assessment, focused on data security, data privacy and cloud security, is not a one-time report but instead the starting point for an ongoing practice of data security posture management (DSPM). With the adoption of DSPM practices, which encompass everything discussed above, a retail organization can continuously assess and manage its data security practices.

DSPM involves identifying and prioritizing security risks, implementing appropriate safeguards and monitoring security controls to ensure their effectiveness. It also incorporates the defining and monitoring of incident response practices to deal with breaches and lapses that put the integrity of the program at risk. Key activities in the DSPM include:

- **Data classification and sensitivity labeling:** Before data enters the data lakehouse, classify it based on sensitivity — e.g., personally identifiable information (PII), financial data. Apply appropriate security labels and controls based on its classification.
- **Data minimization:** Implement the principle of least privilege, ensuring that only authorized users have access to specific data subsets commensurate with their roles and responsibilities. Minimize the overall volume of sensitive data stored.
- **Data residency and governance:** Define clear data residency requirements based on applicable privacy regulations and enforce data governance policies that dictate data handling, usage and retention lifecycles.
- **Continuous data monitoring:** Employ data activity monitoring (DAM) solutions to detect anomalous access patterns, suspicious data modifications or unauthorized transfers. Analyze data flows and usage trends to identify potential risks.
- **Data quality checks:** Implement data quality checks to ensure data integrity and consistency. Identify and mitigate potential data anomalies that could indicate manipulation or security breaches.
- **Privacy impact assessments (PIAs):** Conduct PIAs before introducing new data sources or data usage initiatives. Evaluate potential privacy risks and implement appropriate safeguards.

- **Threat detection and monitoring:** Fine-tune threat detection and monitoring tools to identify threats specific to the data lakehouse environment and new data types. This may include intrusion detection systems (IDS), intrusion prevention systems (IPS) or user behavior analytics (UBA) tools.
- **Security configuration management:** Enforce secure configuration settings for data lakehouse components, such as default passwords, access permissions and data encryption settings.
- **Security incident response:** Establish a robust incident response plan to effectively detect, respond to and recover from data security incidents. Ensure the plan is continually updated to address potential breaches involving new data sources or usage scenarios. This includes having clear communication protocols, escalation procedures and forensic investigation capabilities. Conduct regular tabletop exercises to test preparedness.
- **Compliance monitoring:** Continuously monitor compliance with applicable data security and privacy regulations. Assess compliance implications of introducing new data types or using data for novel purposes.

Additional considerations:

- **Security awareness training:** Educate employees on responsible data handling and classification practices and secure data access procedures.
- **Penetration testing:** Conduct regular penetration testing to identify and address potential security weaknesses in the data lakehouse environment. In addition to internal pen testing, consider enrolling in bug bounty initiatives to perform pen testing against trusted platform partners. Bug bounty programs leverage the expertise of external security researchers to identify and report vulnerabilities.
- **Third-party vendor management:** Implement robust security controls for third-party vendors accessing or processing data within the data lakehouse.



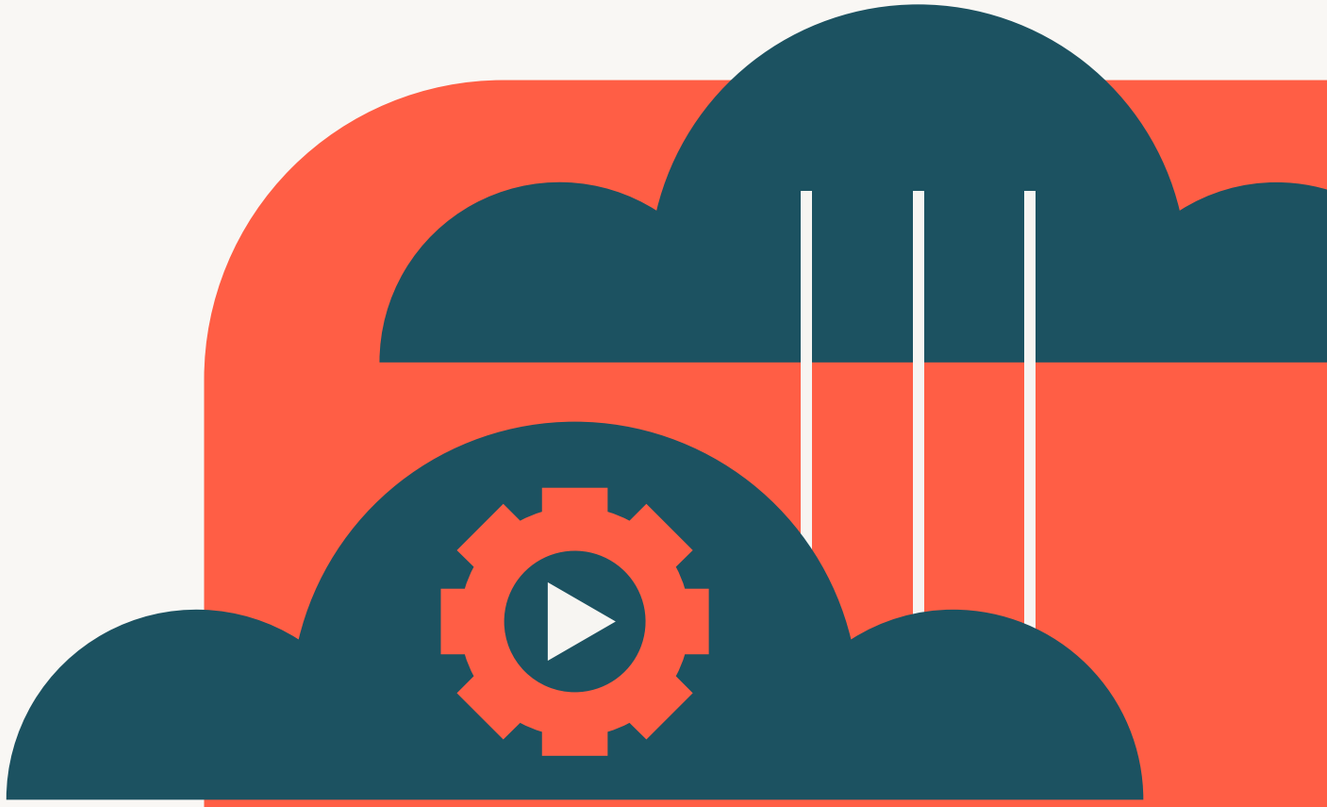
Conclusion

Securing the next-generation customer experience requires a comprehensive approach that addresses data security, data privacy and cloud security considerations. By implementing the recommended assessments, strategies and best practices, retailers can effectively protect sensitive customer data, comply with applicable regulations and enhance their overall cybersecurity posture while maximizing the benefits of data lakehouse technology for a successful implementation.

Databricks would like to thank LFG Security Consulting for their collaboration on the development of this asset. To learn more about the security and privacy assessment services they provide, please visit them at https://www.lfgsecurity.com/assessment-services.

About Databricks

Databricks is the data and AI company. More than 10,000 organizations worldwide — including Comcast, Condé Nast, Grammarly and over 50% of the Fortune 500 — rely on the Databricks Data Intelligence Platform to unify and democratize data, analytics and AI. Databricks is headquartered in San Francisco, with offices around the globe, and was founded by the original creators of Lakehouse, Apache Spark™, Delta Lake and MLflow. To learn more, follow Databricks on LinkedIn, X and Facebook.



Sign up for a free trial

databricks

© Databricks 2023. All rights reserved.
Apache, Apache Spark, Spark and the Spark logo are trademarks of the Apache Software Foundation. Privacy Policy | Terms of Use